novosapien

# Data Protection Guidelines

TXN Knowledge Hub AI Assistant: interim hosting by Novosapien

**Version** 1.0 **Date** 13 November 2026 **Parties** TXN Global Limited and Novosapien Global Ltd **Status** Working document

This is the agreed factual position on personal data in the TXN Knowledge Hub AI assistant while Novosapien hosts it. It is the companion to the **Data Processing Agreement (Interim Hosting)**: this document explains what happens to data and why, the Agreement makes it binding. It is written to be given to TXN's counsel, to answer Direct Transact's interim launch questions in one place, and to be updated as the position changes.

> **The one thing to read first.** For this interim period Novosapien *hosts* the AI assistant, in Novosapien's own Azure subscription, using Novosapien's own model account. That makes Microsoft, Google and Sentry **Novosapien's sub-processors**, and makes Novosapien accountable for the hosting itself. That is a different position from the rest of the engagement, where Direct Transact hosts and those providers are TXN's. It is the reason a separate agreement is needed now rather than later, and it reverses at Production Cutover.

## 1 What the interim service is, and what it is not

The interim service is the **documentation co-pilot** and the **documentation server** behind the Knowledge Hub. It answers a developer's question from TXN's published documentation. It runs in Novosapien's Azure subscription in **North Europe (Ireland)** until it moves to hosting provided by Direct Transact in the TXN Azure subscription.

| It does | It does not |
|---|---|
| • Answer questions from TXN's **public documentation**<br>• Run example API calls against a **mock API**<br>• Let a visitor return to their own chat within 72 hours<br>• Rate limit per visitor to protect the service | • Hold any **TXN client data**<br>• Hold any **cardholder data**<br>• Hold any **TXN credentials**<br>• Reach **TxnGlobal.API**<br>• Require a sign-in, or hold names or email addresses<br>• Carry over the pilot sign-up records |

That scope is written into clause 1.2 of the Agreement and cannot change without TXN's written agreement. It is also what keeps the risk small: the most sensitive thing the service can hold is text a visitor chose to type.

## 2 The data map

| Data | Where it lives | How long | Who can reach it |
|---|---|---|---|
| **Visitor IP address** | Azure Front Door firewall logs only. The assistant itself never reads, stores or logs it | **30 days** | Ireland. Authorised Novosapien engineers could technically open the logs. Clause 6.2 of the Agreement says they will not, except for a named security or support purpose, and logs every access |
| **Browser identifier** | A random value in the visitor's browser that links them to their own chats. Session storage, so it dies when the tab closes | **72 hours** after last activity, server side | Nobody outside the browser. It is never sent to the model |
| **Chat content** | The assistant's own database | **72 hours** after the last message | Ireland. The application's own database role and authorised Novosapien engineers |
| **Sanitised chat content** | The long-term store, used to find where the documentation needs to improve | As long as the purpose requires | Ireland, with the **browser identifier stripped** before it is written |
| **Application logs** | Azure Log Analytics. Tool-call arguments and results, plus a one-line request summary. No IP addresses, no browser identifiers, and **not the visitor's message as typed** | **30 days** | Ireland. Can be forwarded to Direct Transact's Microsoft Sentinel |
| **Error reports** | Sentry, on Novosapien's account, configured not to send IP addresses | Provider default | Frankfurt, Germany |
| **Database backups** | Azure managed backups | **7 days** | Ireland |

> **The IP address never reaches the model.** The only reason it exists at all is Azure Front Door, which needs it to run a firewall and a per-visitor rate limit on a surface with no sign-in. No model provider sees it, and neither does the browser identifier.

### Where 72 hours came from

It is a **functional number, not a regulatory one**. Comparable services commonly use 24 hours. TXN chose 72 so a visitor can return to a chat the next day, while keeping the exposure short. It is the same

number TXN has asked Direct Transact to apply to the public sandbox, which is still to be confirmed with Direct Transact in writing.

## 3 Who is who under the GDPR

| Party | Role | What it means in practice |
|---|---|---|
| **TXN Global Limited** | CONTROLLER | Decides why and how the data is processed. Owns the privacy notice, the acceptable use policy, the lawful basis and the legitimate interest assessment. Established in Cyprus, so the **EU GDPR** applies |
| **Novosapien Global Ltd** | PROCESSOR | Processes only on TXN's documented instructions. Hosts the interim service, holds the model account, engages the three sub-processors below and is fully liable for them. Processes in the United Kingdom, so the **UK GDPR** applies to that processing |
| **Microsoft (Azure)** | NOVOSAPIEN SUB-PROCESSOR | Hosting, database, backups and all logs, including the firewall logs that hold IP addresses. North Europe (Ireland) |
| **Google (Gemini on Vertex AI)** | NOVOSAPIEN SUB-PROCESSOR | Receives the visitor's question and the public documentation. No IP address, no browser identifier. EU multi-region. Google acts as processor under its own Data Processing Addendum |
| **Sentry** | NOVOSAPIEN SUB-PROCESSOR | Error reports and performance data, configured to send no IP addresses. EU region, Frankfurt |
| **Direct Transact** | NOT A PARTY TO THIS PROCESSING | Does not host or access the interim service. From Production Cutover it hosts the service in the TXN subscription as TXN's own provider, and this arrangement ends |
| **Stackworx** | NOT A PARTY TO THIS PROCESSING | Builds and supports the Knowledge Hub, not the AI assistant. Confirmed on 11 November that nothing is needed from Stackworx here |
| **Umbraco, TXN's auth server** | NOT SUB-PROCESSORS | Umbraco is the source of the documentation and receives nothing from visitors. The assistant only reads the auth server's public signing keys |

LangSmith tracing and Supabase are **not used** by the interim service, and the outbound firewall blocks both.

## 4 The lawful basis

TXN owns the lawful basis as controller. The position the parties have taken, and the reasoning behind it:

| Processing | Basis | Why |
|---|---|---|
| **Firewall and security logs (IP addresses)** | Legitimate interest, Article 6(1)(f) | **Recital 49** names network and information security as a legitimate interest, and gives prevention of unauthorised access and denial-of-service attacks as examples. Thirty days is unremarkable for this purpose |
| **Chat content and the browser identifier** | Legitimate interest, Article 6(1)(f) | The visitor has asked for the service. The identifier exists only so they get their own chat back |
| **Sanitised chats, to improve the documentation** | Legitimate interest, Article 6(1)(f) | The browser identifier is stripped, so the retained record cannot be tied back to a visitor. The purpose is improving TXN's own documentation |

> **Open item.** A short written **legitimate interest assessment** does not exist yet. EDPB Guidelines 1/2024 set a three-step test: a lawful interest, necessity, and a balance against the individual's rights. One page covers it for each of the three rows above. It should be in place before the privacy notice is finalised.

### Is an IP address personal data? Yes, and it is treated as such.

An IP address is personal data where the holder has a lawful route to link it to a person, which the Court of Justice established in **Breyer (C-582/14)**; Recital 30 names IP addresses as online identifiers. The parties do not argue the point. The firewall logs are treated as holding personal data, with a basis, a retention period and a line in the privacy notice.

### And the random browser identifier?

Also personal data while it exists. Article 4(1) lists an online identifier as a means of identification, and **EDPS v SRB (C-413/23 P, September 2025)** confirmed the test is whether the holder has means reasonably likely to identify the person. The exposure is small and getting smaller: it survives one tab session in the browser, the server deletes it 72 hours after the last activity, it is stripped from anything kept longer, and the model never receives it.

## 5 The principles both parties operate to

These are the working rules behind the Agreement. They came out of the alignment call on 11 November 2026, and they are what should be applied to any question this document does not answer.

| Principle | What it means |
|---|---|
| **Personal data is never asked for** | No field, prompt or journey requests it. The acceptable use policy tells visitors not to enter it. If a visitor enters it anyway, nothing is done with it beyond the retention periods above. The sandbox reinforces this: the APIs need no cardholder name or address, so a completely blank cardholder can be created |

| | |
|---|---|
| **Store it in Europe, and keep access inside Europe or adequacy** | Everything is stored in Europe. Model inference runs on the EU multi-region endpoint, never a global one. The only access from outside the EU is Novosapien's engineers in the United Kingdom, which the European Commission's adequacy decision covers |
| **The control is the agreement, not a claim that access is impossible** | Novosapien's engineers can technically open the Front Door logs. Nobody can credibly promise otherwise in any IT system. What matters is what access is granted, what anyone would use it for, and what happens if it is misused. Clause 6.2 of the Agreement makes the limit binding, requires every access to be by a named person and logged, and forbids approaching an internet provider to identify an IP address |
| **Minimise what links one record to another** | The chain of browser to identifier to chat to IP address is broken at the one point it could have been joined: the identifier moves to session storage, and is stripped from anything kept beyond 72 hours |
| **Risk-based, proportionate** | Controls are sized to a public documentation assistant that holds no client data, not to a system handling cardholder records. Where a control costs more than the risk it removes, say so and record the decision rather than engineering around a hypothetical |
| **Write the position down once, and keep it current** | This document and the Agreement are the single answer to a questionnaire, a privacy notice, a counsel review or a Direct Transact control. When the service changes, they change in the same week |

## 6 Browser storage, and whether a consent banner is needed

Article 5(3) of the ePrivacy Directive requires consent to store information on a visitor's device, but exempts storage strictly necessary for a service the visitor has asked for. **EDPB Guidelines 2/2023** confirm the rule covers browser storage and not only cookies, and **WP29 Opinion 04/2012** treats a session identifier for a user-requested function as exempt.

The browser identifier exists only to give the visitor their own chat back, and it lasts one tab session. The exemption applies, so **no consent banner is needed for it**. Cyprus applies the rule through its own national law, and TXN's counsel should confirm the local implementation.

## 7 What the privacy notice has to say

The notice is TXN's, and it needs four things for this service:

- **The purposes and the lawful basis** for each of the three rows in section 4.
- **The retention periods**: 30 days for security logs, 72 hours after the last message for chats.
- **The recipients, or the categories of recipient** (Article 13(1)(e)).
- A line telling visitors **not to enter personal data**, matching the acceptable use policy.

### Does it have to name Microsoft and Google?

No, not in the notice itself. The WP29 transparency guidelines (WP260) say to name recipients where possible and otherwise give categories that are as specific as possible, so **"cloud hosting provider" and "AI model provider"** is sufficient. But in **Österreichische Post (C-154/21)** the Court held that a person making an access request under Article 15 is entitled to the *actual* recipients. So TXN must be able to name them on request, which is what Annex C of the Agreement provides. The practical observation from the 11 November call holds: naming a cloud provider in a privacy notice is unusual, and TXN's sample notices are worth checking before deciding.

## 8 Access, deletion and other data subject requests

The service has no accounts and holds no names or email addresses. **Article 11** says a controller does not have to collect extra data purely to identify a person, and Articles 15 to 20 then do not apply unless the person supplies information that allows identification.

| Request | What happens |
|---|---|
| **"Delete my data", with no identifier** | TXN cannot find the chats, and is not required to collect more data in order to. The chats delete themselves 72 hours after the last message in any case |
| **"Delete my data", with a chat identifier** | Novosapien deletes or exports that chat on TXN's instruction within 5 Business Days, provided it has not already expired |
| **A request about the pilot sign-up records** | Out of scope here. Those records are not on the interim service and do not migrate to it |
| **A request received by Novosapien directly** | Passed to TXN without responding. TXN answers as controller |

## 9 What changes at Production Cutover

Production Cutover is the point, confirmed in writing by both parties, at which the assistant moves to hosting in the TXN Azure subscription operated by Direct Transact. Nearly every line in this document changes with it.

| | Now (interim) | From Production Cutover |
|---|---|---|
| **Who hosts** | Novosapien, in Novosapien's Azure subscription, North Europe | Direct Transact, in the TXN Azure subscription |
| **Who holds the model account** | Novosapien's Google Cloud account; cost recharged to TXN | TXN or Direct Transact. The change is configuration only |
| **Microsoft, Google, Sentry** | **Novosapien's sub-processors** | **TXN's processors.** TXN contracts for them directly |

| | | |
|---|---|---|
| **Who controls access to production** | Authorised Novosapien engineers | Direct Transact. Novosapien holds no standing production access |
| **Who deploys** | Novosapien | Direct Transact only, through its own pipeline and gates |
| **Transfer mechanisms** | Novosapien's responsibility | TXN's responsibility, on TXN's own accounts |
| **This Agreement** | In force | Ends. Novosapien deletes the interim database, logs and backups and confirms in writing within 10 Business Days |

Support is a separate question from hosting, and it does not end at cutover. Novosapien supports and maintains the AI layer; Stackworx supports and maintains the Knowledge Hub. That split needs its own paper, which is the Support and Maintenance agreement on the list below.

## 10 Where Direct Transact's interim launch questions are answered

Direct Transact issued 41 items, of which 9 are gated on the interim launch. The six that concern Novosapien are answered in the *Knowledge Hub AI Assistant: Interim Hosting Answers* paper of 11 November, and are now carried into binding form as follows.

| Item | Topic | Where it now lives |
|---|---|---|
| **Q01** | Interim hosting: scope, tenant, connection, authentication, Sentinel, access, cutover, deletion | Agreement clauses 1.1, 1.2, 5.4, 10, 11.3; Annex A; Annex B(a), B(b), B(d) |
| **Q03** | Third-line support and incident notification | Incident notification: clause 7 (24 hours). Support hours and escalation: the Support and Maintenance agreement, still to be papered |
| **Q15** | Model product, tier and account owner | Annex C: Gemini on Vertex AI, Novosapien's Google Cloud account, transferable to a TXN or Direct Transact project by configuration |
| **Q16** | Model terms: training, retention, region, DPA | Agreement clauses 5.1 to 5.3; Annex C |
| **Q18** | Other parties receiving data | Annex C, including the parties that are expressly not sub-processors |
| **Q21** | Storage, retention, encryption, access and access logging | Annex A retention schedule; Annex B(c), B(d), B(g) |

| | | |
|---|---|---|
| **Q23** | Logs and telemetry: what captures prompts or tool results | Annex A; Annex B(g) |
| **X1** | TXN decision: final retention | Annex A. 72 hours for chats, checkpoints and session data. No sign-up records on the interim service |
| **X2** | TXN decision: model provider and processing region | Annex C. Gemini on Vertex AI, EU multi-region, public documentation only |

Two Direct Transact recommendations differ from what is in place, both in TXN's favour, and both are deliberate: retention is **72 hours rather than 30 days** for chats and checkpoints, and **no pilot sign-up records migrate** at all.

## 11 Open items

What is still to be done, who owns it, and by when. This is the live list; it should be reviewed at the standing weekly review until it is empty.

| Item | Owner | By when | Status |
|---|---|---|---|
| Move the browser identifier to session storage | Novosapien | Before launch | OPEN |
| Strip the browser identifier when a chat is written to the long-term store | Novosapien | Before launch | OPEN |
| Disable model prompt caching, and request the abuse-monitoring exception | Novosapien | Before go-live | OPEN |
| Decide whether a browser identifier is needed at all | Novosapien | Not dated | OPEN |
| Put personal data out of scope in the acceptable use policy | TXN (Dörte) | Before launch | OPEN |
| Write the legitimate interest assessment for the three rows in section 4 | Both | Before the privacy notice is finalised | OPEN |
| Decide whether the privacy notice names cloud and model providers, against TXN's sample notices | TXN (Ian) | Before the privacy notice is finalised | OPEN |
| Confirm how Cyprus implements Article 5(3) of the ePrivacy Directive | TXN's counsel | Before the privacy notice is finalised | OPEN |
| Confirm the 72-hour sandbox clearing with Direct Transact in writing | TXN (Michael) | Not dated | OPEN |

| | | | |
|---|---|---|---|
| Agree the Sentinel log forwarding connection | Both, with Direct Transact | Not dated | OPEN |
| Supply TXN's company (HE) number and the named contact for Annex A | TXN | Before signature | OPEN |
| Confirm the launch date: 16 or 17 November | TXN (Ian) | Now | OPEN |
| Paper the Support and Maintenance agreement for the AI layer | Both | Immediately after launch | OPEN |
| Sign the Master Service Agreement, with this arrangement appended | Both | Agenda for 24 November | OPEN |

## 12 Sources

| Category | Reference |
|---|---|
| **Legislation** | Regulation (EU) 2016/679 (EU GDPR), Articles 4(1), 5, 6(1)(f), 11, 13, 15, 28, 32 to 36; Recitals 26, 30, 49. UK GDPR and Data Protection Act 2018. Directive 2002/58/EC (ePrivacy), Article 5(3). Regulation (EU) 2022/2554 (DORA) |
| **Case law** | CJEU C-582/14 *Breyer* (dynamic IP addresses as personal data). CJEU C-154/21 *Österreichische Post* (right to know the actual recipients). CJEU C-413/23 P *EDPS v SRB* (pseudonymised data) |
| **Regulator guidance** | EDPB Guidelines 1/2024 on legitimate interest. WP29 Guidelines on transparency, WP260 rev.01. EDPB Guidelines 2/2023 on the technical scope of Article 5(3). WP29 Opinion 04/2012 on cookie consent exemption, WP194 |
| **Transfers** | European Commission adequacy decision for the United Kingdom, renewed December 2025 and running to 27 December 2031 |
| **Provider terms** | Microsoft Products and Services Data Protection Addendum. Google Cloud Data Processing Addendum, Vertex AI data residency and zero data retention. Sentry Data Processing Addendum and data storage location |
| **Project documents** | *Knowledge Hub AI Assistant: Interim Hosting Answers*, Novosapien, 11 November 2026. *TXN AI Services: Questions and Decisions Required from TXN* v1.6, Direct Transact, November 2026. Personal data alignment call, 11 November 2026 |

> **Not legal advice.** This document records the factual position and the parties' reasoning. TXN's own counsel should confirm the Cyprus-specific points, the legitimate interest assessment and the privacy notice before launch.